

Web Cache Deception — Exploiting cache server normalization for web cache deception

Plataforma: PortSwigger Web Security Academy

Ferramenta: Burp Suite

Categoria: Web Security / Cache Poisoning & Cache Deception

Escopo: Laboratório controlado

1. Objetivo

Explorar uma discrepância na forma como o servidor de cache e o servidor de origem normalizam e interpretam o caminho da URL, utilizando a normalização realizada pelo servidor de cache para demonstrar um cenário de Web Cache Deception.

O objetivo final do laboratório foi obter, em ambiente controlado, a chave de API associada ao usuário **Carlos**.

2. Descrição da vulnerabilidade

Web Cache Deception ocorre quando um atacante consegue induzir um mecanismo de cache, como um proxy reverso ou CDN, a armazenar uma resposta dinâmica ou sensível como se fosse um recurso estático.

O problema surge quando diferentes componentes da infraestrutura interpretam o mesmo caminho de URL de maneiras distintas:

- O servidor de origem interpreta a requisição como um endpoint dinâmico;
- O mecanismo de cache considera o caminho como um recurso estático e potencialmente cacheável;
- A resposta dinâmica pode, então, ser armazenada e posteriormente disponibilizada por uma URL aparentemente pública.

3. Conhecimento necessário

Normalização do caminho

Identificar se o cache e o servidor de origem normalizam o caminho da URL.

Regras de cache de diretório estático

Identificar as regras utilizadas pelo mecanismo de cache para classificar determinados diretórios como recursos estáticos.

Discrepância na interpretação de delimitadores

Identificar discrepâncias na forma como o cache e o servidor de origem interpretam caracteres como delimitadores e utilizá-las para explorar a diferença de processamento da URL.

Exploração da normalização pelo servidor de cache

Explorar a normalização realizada pelo servidor de cache por meio de uma sequência de travessia de caminho codificada e de um delimitador interpretado pelo servidor de origem, mas não pelo cache.

4. Impacto potencial

A exploração desse tipo de falha pode resultar em:

- Exposição de dados sensíveis;
- Vazamento de chaves de API;
- Exposição de tokens ou credenciais;
- Acesso não autorizado a informações de outros usuários;
- Persistência temporária dos dados enquanto a resposta permanecer armazenada no cache.

5. Ambiente e acessos

O laboratório disponibiliza:

- Uma conta comum para análise do comportamento da aplicação;
- A página inicial da aplicação;
- O endpoint `My Account`;
- Uma lista de possíveis caracteres delimitadores para teste.

Credenciais do laboratório: `wiener:peter`

As credenciais acima pertencem exclusivamente ao ambiente controlado fornecido pelo laboratório.

6. Metodologia

6.1 Identificação do endpoint dinâmico

Foi identificado o endpoint `My Account`, responsável por retornar informações específicas do usuário autenticado, incluindo uma chave de API.

6.2 Análise das regras de recursos estáticos

Foi identificado o diretório utilizado pela aplicação para recursos aparentemente estáticos:

- /resources

O objetivo foi identificar padrões que poderiam levar o mecanismo de cache a classificar uma URL como cacheável.

6.3 Análise da normalização pelo servidor de cache

Foi analisado o comportamento do mecanismo de cache diante de segmentos de pontos codificados no caminho da URL.

A análise teve como objetivo verificar se o cache resolvia os segmentos codificados enquanto o servidor de origem mantinha a sequência codificada no caminho.

6.4 Identificação dos delimitadores

Durante os testes, foram identificados os seguintes elementos utilizados na exploração:

A discrepância relevante foi observada na combinação entre a sequência codificada e o delimitador interpretado pelo servidor de origem.

1. %23%2f%2e%2e%2f
2. ?
3. Esses elementos permitiram explorar a diferença de interpretação entre o servidor de cache e o servidor de origem.

7. Construção da requisição

A estrutura conceitual utilizada foi:

my-account%23%2f%2e%2e%2fresources?wcd

A sequência de travessia do caminho foi codificada para evitar comportamentos inesperados durante o processamento da URL.

O servidor de origem interpreta o delimitador e trata o caminho de forma diferente, enquanto o cache realiza a normalização da sequência codificada. Essa discrepância permite que a resposta dinâmica seja tratada pelo mecanismo de cache de acordo com suas regras de recursos estáticos.

8. Validação da exploração

A discrepância identificada permitiu induzir o armazenamento de uma resposta dinâmica no mecanismo de cache.

Após a validação do comportamento, foi possível concluir o laboratório e obter a chave de API associada ao usuário Carlos.

9. Resultado

Status: Concluído com sucesso.

O laboratório demonstrou que uma discrepância na normalização realizada pelo servidor de cache pode permitir que conteúdo dinâmico e sensível seja armazenado indevidamente por um mecanismo de cache.

Os elementos identificados para reproduzir o comportamento vulnerável foram %23%2f%2e%2e%2f e ?.

10. Conclusão

O exercício demonstrou a importância de analisar como o servidor de cache e o servidor de origem normalizam e interpretam os caminhos das URLs.

Quando o cache e o servidor de origem processam os mesmos elementos de forma diferente, essa discrepância pode ser explorada para provocar o armazenamento de uma resposta dinâmica sob uma URL considerada estática pelo cache.

O Burp Suite foi utilizado para analisar as requisições, testar o comportamento da normalização e identificar a discrepância entre o cache e o servidor de origem.

11. Evidências

As evidências visuais da execução, incluindo capturas de tela das requisições, testes realizados no Burp Suite e validação do comportamento de cache, serão disponibilizadas separadamente em um arquivo de evidências.

12. Referência do laboratório

PortSwigger Web Security Academy — Web Cache Deception